

Fix Production Demo-Data Leak — Step-by-Step Playbook

Problem: Production `corporate-feast.emergent.host` currently returns `{demo_enabled: true, environment: preview}`. `CRAVITOO_ENV=production` was not set at deploy time, so the backend seeded demo data into your real production database.

Goal: Set the env var, then safely remove the 114 demo rows that leaked in.

Time: ~15 minutes total.

STEP 1 — Set `CRAVITOO_ENV=production` in the Emergent Deploy panel

1. Open the Emergent chat interface.
2. Click **Deploy** (button in the chat input area or top nav).
3. Find the **Environment Variables** section in the Deploy modal.
4. Add this row exactly:

Key	Value
<code>CRAVITOO_ENV</code>	<code>production</code>

5. Click **Deploy** (this ships a new image with the env var applied).
6. Wait for the deploy to complete (~1-2 minutes).

Verify Step 1 worked

Run this from your laptop:

```
curl https://corporate-feast.emergent.host/api/admin/demo/enabled
```

✓ Expected: `{"demo_enabled": false, "environment": "production"}` ✗ If still `"environment": "preview"` → the env var wasn't applied. Redo Step 1.

STEP 2 — Back up the production database

Do NOT skip this. Every step below is reversible only if you have this backup.

You need the **production MongoDB URI** and **DB name** — either from the Emergent Deploy env-vars panel or from your ops docs. If you don't have them, contact Emergent Support to run the dump on your behalf.

```
BACKUP_DIR="/tmp/cravitoo-prod-backup-$(date -u +%Y%m%d-%H%M) "
mkdir -p "$BACKUP_DIR"

mongodump --uri="<PROD_MONGO_URL>" --db="<PROD_DB_NAME>" \
          --out="$BACKUP_DIR" --gzip

# Confirm the dump exists and has volume
ls -lah "$BACKUP_DIR/<PROD_DB_NAME>/"
du -sh "$BACKUP_DIR"

# Record the SHA-256 of the orders and users dumps for the audit trail
sha256sum "$BACKUP_DIR/<PROD_DB_NAME>/users.bson.gz" \
          "$BACKUP_DIR/<PROD_DB_NAME>/orders.bson.gz" > "$BACKUP_DIR/sha256.txt"
cat "$BACKUP_DIR/sha256.txt"
```

Save `$BACKUP_DIR` — you need it for Step 4 if anything goes wrong.

STEP 3 — Dry-run the demo-data cleanup

The cleanup script is already in the codebase at `backend/scripts/phase1_prod_demo_cleanup.py`. **Dry-run first — it does zero writes.**

```
MONGO_URL="<PROD_MONGO_URL>" DB_NAME="<PROD_DB_NAME>" \
python /app/backend/scripts/phase1_prod_demo_cleanup.py
```

Expected output (numbers may differ on your prod):

```
users  (7 rows):
  • demo@techcorp.com
  • employee@techcorp.com
  • finance@cravitoo.com [demo_tag=cravitoo_pune_demo]
  • info@cravitoo.com    [demo_tag=cravitoo_pune_demo]
  • siteadmin@techcorp.com
```

```

• vendor@atmega.com      [demo_tag=cravitoo_pune_demo]
• vendor@spicekitchen.com

companies  (1 row):
• Tech Corp

vendors  (2 rows):
• Spice Kitchen
• ATMEGO      [demo_tag=cravitoo_pune_demo]

sites  (2 rows):
• Tech Corp - Bangalore HQ
• Cravitoo - Pune Office      [demo_tag=cravitoo_pune_demo]

allowed_domains  (1 row):
• techcorp.com

vendor_site_mappings  (35 rows)
menu_items            (?? rows)

TOTAL: ~114 row(s)

Protected (will NEVER be deleted):
emails:      ['admin@cravitoo.com']
domains:     ['cravitoo.com']
companies:   ['Cravitoo']

```

Sanity-check the list

Before proceeding, review these emails carefully:

- `finance@cravitoo.com` and `info@cravitoo.com` — these are **demo accounts** seeded with a default password. If you are NOT using them as real staff mailboxes on production, delete them. If you ARE, add them to the `PROTECTED_EMAILS` list at the top of the script and re-run.
- `admin@cravitoo.com` is automatically protected — it will NOT be touched.
- The real `Cravitoo` company + `cravitoo.com` domain are automatically protected — they will NOT be touched.

If the list looks right, continue to Step 4. If anything looks wrong, STOP and message me.

STEP 4 — Apply the cleanup

The script REFUSES to actually delete unless you set `I_HAVE_BACKED_UP_ORDERS=YES` AND

pass — apply. This is intentional belt and braces.

```
MONGO_URL="<PROD_MONGO_URL>" DB_NAME="<PROD_DB_NAME>" \  
I_HAVE_BACKED_UP_ORDERS=YES \  
python /app/backend/scripts/phase1_prod_demo_cleanup.py --apply
```

Expected output:

```
Applying cleanup...  
Done.  
  users: 7  
  companies: 1  
  vendors: 2  
  sites: 2  
  allowed_domains: 1  
  vendor_site_mappings: 35  
  menu_items: 66  
  _backup_collection: _prod_cleanup_backup_20260624_083012  
  
Rollback (if needed):  
  db._prod_cleanup_backup...find().forEach(row => db.getCollection(row._source).ins
```

Every deleted document is copied into `_prod_cleanup_backup_<timestamp>` in the same DB — a second layer of undo on top of the mongodump.

STEP 5 — Verify the fix

Run these two checks:

5a. Env is now production

```
curl https://corporate-feast.emergent.host/api/admin/demo/enabled
```

✓ `{"demo_enabled": false, "environment": "production"}`

5b. Demo accounts are gone

Try to log in to the admin app as `demo@techcorp.com` / `demo123`:

```
curl -X POST https://corporate-feast.emergent.host/api/auth/login \  
-H "Content-Type: application/json" \  
-d '{"email": "demo@techcorp.com", "password": "demo123"}'
```

✓ Expected: `401 invalid credentials` (the account no longer exists). ✗ If it returns 200 with a token → the deletion didn't apply. Roll back and try again.

5c. Real admin still works

```
curl -X POST https://corporate-feast.emergent.host/api/auth/login \
-H "Content-Type: application/json" \
-d '{"email":"admin@cravitoo.com","password":"<your_real_prod_password>"}'
```

✓ Returns a valid `access_token`.

STEP 6 — (Optional) Purge the cleanup-backup collection after 30 days

Once you're sure nothing was lost, you can remove the safety-net collection:

```
mongosh "<PROD_MONGO_URL>/<PROD_DB_NAME>"
> db._prod_cleanup_backup_20260624_083012.drop();
```

ROLLBACK — if anything goes wrong

Option A — Fast, in-DB rollback (recovers the deleted rows)

```
mongosh "<PROD_MONGO_URL>/<PROD_DB_NAME>"
> db._prod_cleanup_backup_20260624_083012.find()
  .forEach(row => db.getCollection(row._source).insertOne(row._doc));
```

Option B — Full DB restore from mongodump

```
mongorestore --uri="<PROD_MONGO_URL>" --db="<PROD_DB_NAME>" \
--drop --gzip "$BACKUP_DIR/<PROD_DB_NAME>"
```

What I can do vs. what you must do

Task	Who
Write the cleanup script	✓ Done (safe by default, protected lists in place)
Verify the script on preview	✓ Done (114 demo rows identified, real cravitoo.com + Cravitoo company auto-protected)
Set <code>CRAVITOO_ENV=production</code> on prod	✗ You (Emergent Deploy panel — I don't have UI access)
Take the mongodump	✗ You (you have the PROD_MONGO_URL, I don't)
Run the cleanup script	✗ You (needs prod DB credentials)
Verify via curl (Step 5)	✓ I can do this — paste back "done" and I'll run the 3 curl checks

When you're done with Steps 1–4, message me "done step 4" and I will run Step 5 for you and confirm the fix.

